

Report Tecnico: Sfruttamento di SQL Injection (UNION-based) e Cracking di Credenziali (DVWA)

Configurazione degli Indirizzi IP e Topologia

- Kali Linux (Macchina Attaccante): **192.168.13.100** (Interfaccia di test per l'intercettazione e il cracking offline).
- Target (DVWA / Metasploitable o Ambiente di Test): **192.168.13.150** (Server web ospitante la Web Application vulnerabile).

1. Obiettivo dell'Esercizio

L'obiettivo di questo laboratorio è stato quello di identificare e sfruttare una vulnerabilità di tipo **SQL Injection (UNION-based)** all'interno della Web Application DVWA (impostata a livello di sicurezza *Medium*), estrarre dal database le informazioni riservate degli utenti (inclusi gli hash delle password) e successivamente decifrare l'hash ottenuto tramite un attacco offline di tipo dizionario.

2. Ambiente di Lavoro e Parametri

- **Target (DVWA):** Applicativo web vulnerabile ospitato su ambiente di test.
- **Livello di Sicurezza DVWA:** **MEDIUM** (presenza di filtraggi parziali e sanitizzazione basata su query parametrizzate o escape dei caratteri).
- **Strumenti Utilizzati:** Burp Suite (Repeater), Kali Linux, John the Ripper.
- **Utente Target:** **pablo**
- **Hash Estratto:** **0d107d09f5bbe40cade3de5c71e9e9b7** (MD5)

3. Fasi di Esecuzione e Metodologia

1. Intercettazione e Analisi della Richiesta:

Tramite il proxy intercept di Burp Suite, è stata intercettata la richiesta HTTP GET inviata dall'applicazione. Spostando la richiesta nel modulo **Repeater**, si è analizzato il parametro vulnerabile esposto nell'URL (**?id=...**).

2. Aggiramento dei Filtri e Iniezione (UNION SELECT):

Sfruttando il comportamento del livello *Medium*, che gestisce l'input in modo non completamente sicuro, è stato iniettato un payload basato sull'operatore **UNION SELECT**. Per fare in modo che la prima parte della query originale fallisse restituendo un set vuoto (lasciando spazio ai nostri dati), è stato impostato l'identificativo iniziale a **1** (o valore nullo) concatenando l'istruzione di estrazione:

3. HTTP

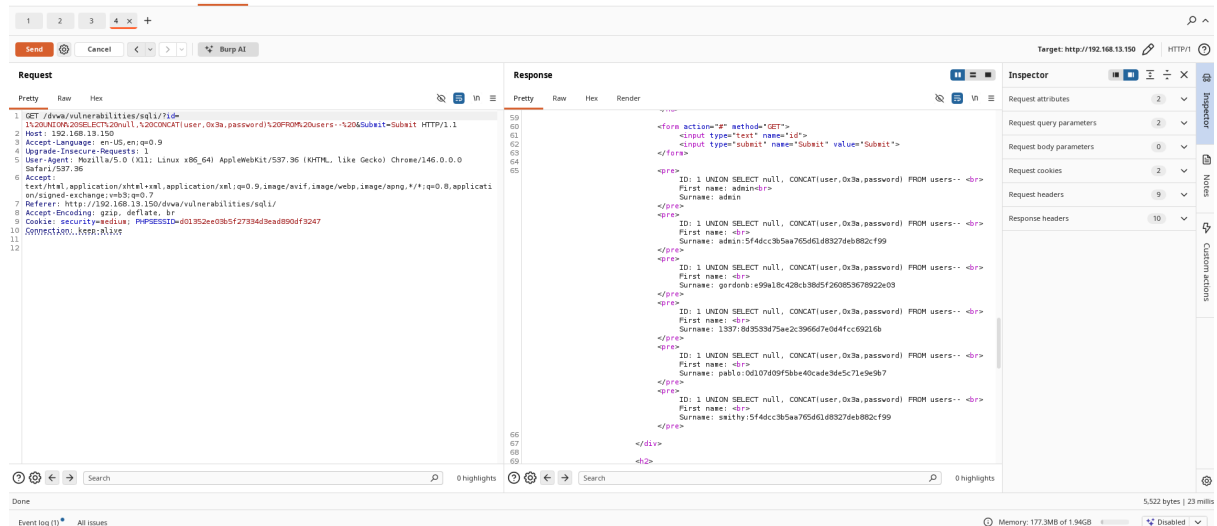
GET

/dvwa/vulnerabilities/sqli/?id=1%20UNION%20SELECT%20null,%20CONCAT(user,0x3a,password)%20FROM%20users--%20&Submit=Submit HTTP/1.1

4.

5. Esfiltrazione dei Dati:

La risposta HTTP del server ha restituito direttamente all'interno della pagina web la lista degli utenti registrati associati ai relativi hash crittografici delle password in formato MD5 (nello specifico, l'hash dell'utente *pablo*).



6. Attacco di Cracking Offline (Post-Exploitation):

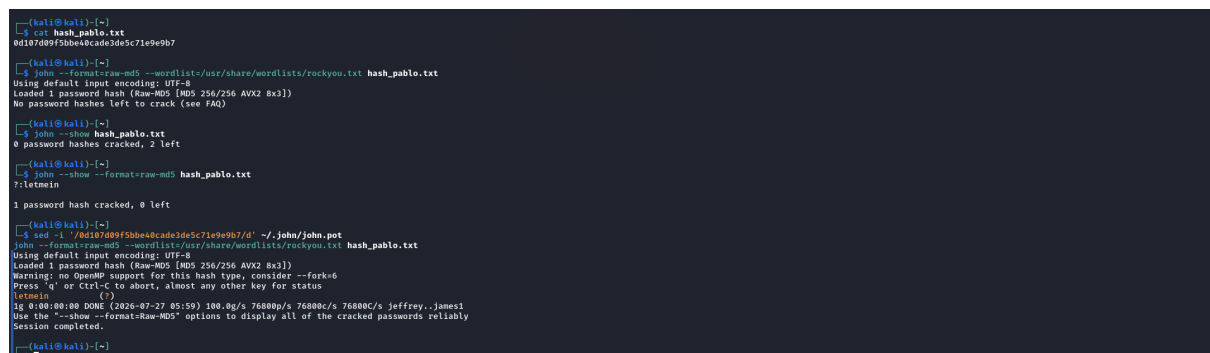
L'hash estratto (0d107d09f5bbe40cade3de5c71e9e9b7) è stato salvato su un file di testo sulla macchina Kali Linux. Successivamente, è stato lanciato lo strumento **John the Ripper** specificando il formato dell'hash (`--format=raw-md5`) e una wordlist di termini comuni (`rockyou.txt`):

7. Bash

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash_pablo.txt
```

8.

9. L'attacco ha portato alla decifrazione dell'hash e al recupero della password in chiaro corrispondente (**letmein**).



4. Conclusioni e Mitigazione

L'esercizio ha dimostrato come una mancata parametrizzazione delle query SQL possa consentire a un malintenzionato di leggere l'intero contenuto del database sottostante. La mitigazione efficace consiste nell'implementare **Prepared Statements (Query Parametrizzate)** e l'uso rigoroso di funzioni di escape o ORM sicuri per qualsiasi input proveniente dall'utente.